

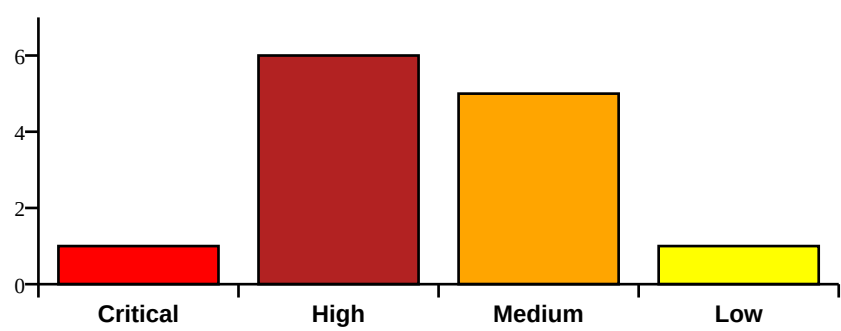
Vulnerability Scan Report

Target URL: http://testphp.vulnweb.com/login.php
Generated (UTC): 2025-12-24 02:59:39Z

Summary

Metric	Count
Total Vulnerabilities	13
Critical Severity	1
High Severity	6
Medium Severity	5
Low Severity	1

Severity Distribution



Detected Vulnerabilities

Type	Location	Evidence / Payload	Severity
XSS	http://testphp.vulnweb.com/login.php	'-alert(1)//	Medium
XSS	http://testphp.vulnweb.com/login.php	alert(1);	Medium
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
SQL Injection	http://testphp.vulnweb.com/login.php	OR '1'='1 --	High
NoSQL Injection	http://testphp.vulnweb.com/login.php	{"\$ne": null}	High
Command Injection	http://testphp.vulnweb.com/login.php	;& ls	Critical
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Application does not enforce HTTPS	High
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Strict-Transport-Security header not set	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Multiple rapid requests allowed without restriction	High

Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Sensitive endpoint accessible without auth: /admin	High
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: No CAPTCHA or bot protection detected	Low
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: PUT method is enabled	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: DELETE method is enabled	Medium

Activity Log

```
[02:58:37] [+] Loaded 6606 payloads for XSS
[02:58:38] [+] Loaded 4 payloads for SQL Injection
[02:58:38] [+] Loaded 3 payloads for NoSQL Injection
[02:58:38] [+] Loaded 4 payloads for Command Injection
[02:58:39] [+] Found: http://testphp.vulnweb.com/login.php
[02:58:39]
=====
[02:58:39] Starting Vulnerability Scan for http://testphp.vulnweb.com/login.php
[02:58:39]
=====
[02:58:39]
===== Testing for XSS =====
[02:58:39]
[+] Testing form in http://testphp.vulnweb.com/login.php
[02:58:50] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[02:58:50] payload: &#x27;-alert(1)//
[02:58:50] Severity: Medium
[02:58:50] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot;
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot;
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot;/></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot;/></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot;><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot;/></td></tr>
</table>
</form>

[02:58:50]
[+] Testing form in http://testphp.vulnweb.com/login.php
[02:58:50] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[02:58:50] payload: <script>alert(1);</script>
[02:58:50] Severity: Medium
[02:58:50] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;
<label>search art</label>
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot;/>
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot;/>
</form>

[02:58:50]
===== Testing for SQL Injection =====
[02:58:50]
[+] Testing form in http://testphp.vulnweb.com/login.php
[02:58:51] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[02:58:51] payload: OR &#x27;1&#x27;=&#x27;1 --
[02:58:51] Severity: High
[02:58:51] form: <form action=&quot;userinfo.php&quot; method=&quot;post&quot; name=&quot;loginform&quot;
<table cellpadding=&quot;4&quot; cellspacing=&quot;1&quot;
<tr><td>Username : </td><td><input name=&quot;uname&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;text&quot;/></td></tr>
<tr><td>Password : </td><td><input name=&quot;pass&quot; size=&quot;20&quot; style=&quot;width:120px;&quot;
type=&quot;password&quot;/></td></tr>
<tr><td align=&quot;right&quot; colspan=&quot;2&quot;><input style=&quot;width:75px;&quot;
type=&quot;submit&quot; value=&quot;login&quot;/></td></tr>
</table>
</form>

[02:58:51]
[+] Testing form in http://testphp.vulnweb.com/login.php
[02:58:51] [***] Possible SQL Injection in form at: http://testphp.vulnweb.com/login.php
[02:58:51] payload: OR &#x27;1&#x27;=&#x27;1 --
[02:58:51] Severity: High
[02:58:51] form: <form action=&quot;search.php?test=query&quot; method=&quot;post&quot;
<label>search art</label>
```

```
<input name=&quot;searchFor&quot; size=&quot;10&quot; type=&quot;text&quot;/>
<input name=&quot;goButton&quot; type=&quot;submit&quot; value=&quot;go&quot;/>
</form>
```

[02:58:51]

===== Testing for NoSQL Injection =====

[02:58:52]

[+] Testing form in http://testphp.vulnweb.com/login.php

[02:58:54]

[+] Testing form in http://testphp.vulnweb.com/login.php

[02:58:54] [***] Possible NoSQL Injection in form at: http://testphp.vulnweb.com/login.php

[02:58:54] payload: {"\$ne";: null}

[02:58:54] Severity: High

[02:58:54] form: <form action="search.php?test=query" method="post">

<label>search art</label>

<input name="searchFor" size="10" type="text"/>

<input name="goButton" type="submit" value="go"/>

</form>

[02:58:54]

===== Testing for Command Injection =====

[02:58:55]

[+] Testing form in http://testphp.vulnweb.com/login.php

[02:58:58]

[+] Testing form in http://testphp.vulnweb.com/login.php

[02:58:58] [***] Possible Command Injection in form at: http://testphp.vulnweb.com/login.php

[02:58:58] payload: ;& ls

[02:58:58] Severity: Critical

[02:58:58] form: <form action="search.php?test=query" method="post">

<label>search art</label>

<input name="searchFor" size="10" type="text"/>

<input name="goButton" type="submit" value="go"/>

</form>

[02:58:58]

===== Testing for Cryptographic Failures =====

[02:58:58]

===== SCANNING http://testphp.vulnweb.com/login.php =====

[02:58:58] [INFO] Checking scheme → http

[02:58:58] [INFO] Initiating TLS handshake

[02:59:03] [SKIP] TLS check skipped → timed out

[02:59:04] [INFO] Checking cipher suite

[02:59:09] [SKIP] Cipher check skipped → timed out

[02:59:09] [INFO] Retrieving TLS certificate

[02:59:14] [SKIP] Certificate check skipped → timed out

[02:59:14] [HTTP] Checking HSTS header

[02:59:14] [HTTP] Response status → 200

[02:59:14] [HTTP] Response headers → {'Server'; 'nginx/1.19.0';, 'Date';
'Wed, 24 Dec 2025 03:00:36 GMT';, 'Content-Type'; 'text/html; charset=UTF-8';,
'Transfer-Encoding'; 'chunked';, 'Connection'; 'keep-alive';,
'X-Powered-By'; 'PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1';, 'Content-
Encoding'; 'gzip'};

[02:59:14] [SCAN] Checking for weak hashes and sensitive data

[02:59:15]

===== REPORT =====

[02:59:15] - [High] HTTPS not enforced

[02:59:15] - [Medium] HSTS header missing

[02:59:15]

===== SCORE =====

[02:59:15] Crypto Risk Score → 50/100

[02:59:15] Risk Level → MEDIUM

[02:59:15]

===== Insecure Design Scan =====

[02:59:15]

[+] Checking rate limiting...

[02:59:16] [LOG] GET /login.php → 200 (len=5523, 0.58s)

[02:59:17] [LOG] GET /login.php → 200 (len=5523, 0.77s)

[02:59:18] [LOG] GET /login.php → 200 (len=5523, 0.75s)

[02:59:19] [LOG] GET /login.php → 200 (len=5523, 0.74s)

[02:59:20] [LOG] GET /login.php → 200 (len=5523, 0.75s)

[02:59:21] [LOG] GET /login.php → 200 (len=5523, 0.75s)

[02:59:21] [LOG] GET /login.php → 200 (len=5523, 0.71s)

[02:59:22] [LOG] GET /login.php → 200 (len=5523, 0.79s)

[02:59:23]

[+] Checking authorization design...

[02:59:24] [LOG] GET /admin → 200 (len=262, 1.06s)

[02:59:24] [LOG] GET /admin/login → 404 (len=153, 0.63s)

[02:59:25] [LOG] GET /administrator → 404 (len=153, 0.63s)

[02:59:26] [LOG] GET /manage → 404 (len=153, 0.63s)

[02:59:26] [LOG] GET /user → 404 (len=153, 0.63s)

[02:59:27] [LOG] GET /account → 404 (len=153, 0.64s)
[02:59:28] [LOG] GET /profile → 404 (len=153, 0.62s)
[02:59:28] [LOG] GET /login → 404 (len=153, 0.63s)
[02:59:29] [LOG] GET /register → 404 (len=153, 0.63s)
[02:59:29] [LOG] GET /auth → 404 (len=153, 0.63s)
[02:59:30] [LOG] GET /api → 404 (len=153, 0.63s)
[02:59:31] [LOG] GET /api/admin → 404 (len=153, 0.63s)
[02:59:31] [LOG] GET /api/private → 404 (len=153, 0.63s)
[02:59:32] [LOG] GET /checkout → 404 (len=153, 0.61s)
[02:59:33] [LOG] GET /payment → 404 (len=153, 0.65s)
[02:59:33] [LOG] GET /orders → 404 (len=153, 0.63s)
[02:59:34] [LOG] GET /upload → 404 (len=153, 0.60s)
[02:59:35] [LOG] GET /debug → 404 (len=153, 0.63s)
[02:59:35] [LOG] GET /test → 404 (len=153, 0.66s)
[02:59:36] [LOG] GET /dev → 404 (len=153, 0.63s)
[02:59:36]
[+] Checking business logic trust...
[02:59:37] [LOG] POST /login.php → 200 (len=5523, 0.61s)
[02:59:37] ✓ Business logic validation detected
[02:59:37]
[+] Checking abuse protection (CAPTCHA)...
[02:59:37] [LOG] GET /login.php → 200 (len=5523, 0.63s)
[02:59:37]
[+] Checking HTTP method exposure...
[02:59:38] [LOG] PUT /login.php → 200 (len=5523, 0.63s)
[02:59:38] [LOG] DELETE /login.php → 200 (len=5523, 0.63s)
[02:59:39] [LOG] TRACE /login.php → 405 (len=157, 0.62s)